
0.1 Análisis de Riesgo

Debido a la naturaleza jurídica, institucional y tecnológica de la plataforma propuesta para la Defensoría de los Derechos Politécnicos (DDP-IPN), resulta indispensable realizar un análisis integral de riesgos que contemple amenazas técnicas, operativas, legales y organizacionales.

El sistema administra información altamente sensible relacionada con denuncias, expedientes digitales, evidencias multimedia y datos personales de la comunidad politécnica. Asimismo, integra componentes distribuidos basados en microservicios, mecanismos de inteligencia artificial y almacenamiento persistente de evidencias, incrementando la superficie de ataque y la complejidad operativa.

Con el objetivo de identificar vulnerabilidades potenciales y establecer estrategias preventivas, correctivas y detectivas, se realizó un análisis estático de seguridad (SAST), evaluación arquitectónica y análisis de gobernanza tecnológica (GRC), considerando atributos de seguridad, disponibilidad, integridad, trazabilidad, confidencialidad y cumplimiento normativo.

0.1.1 Clasificación General de Riesgos

Los riesgos identificados se clasifican en diferentes categorías con base en el impacto que podrían generar sobre la operación de la plataforma.

Tabla 1: Clasificación General de Riesgos

Categoría	Descripción
Seguridad	Amenazas relacionadas con vulnerabilidades de software, ataques externos, robo de información y manipulación de datos.
Legal y Normativo	Riesgos asociados al incumplimiento de normativas institucionales, privacidad y protección de datos personales.
Operacional	Eventos que afectan la continuidad operativa del sistema y los procesos internos de la DDP.
Tecnológico	Problemas derivados de dependencias, infraestructura, microservicios y arquitectura distribuida.
Inteligencia Artificial	Riesgos asociados al desempeño, sesgo y comportamiento del clasificador automático.
Humano y Organizacional	Errores operativos, malas configuraciones y uso inadecuado de la plataforma por parte del personal.
Financiero	Riesgos relacionados con costos operativos, mantenimiento y escalabilidad tecnológica.

0.1.2 Análisis de Riesgo Integral del Sistema

Núcleo Administrativo y Repositorio (Java / PostgreSQL)

Este componente constituye el núcleo de persistencia jurídica y gestión documental de la plataforma institucional.

- **Compromiso de Datos en Reposo:** El uso de mecanismos criptográficos mediante *pgcrypto* y cifrado AES-256 requiere una administración segura de llaves maestras. Una gestión inadecuada expondría información sensible de estudiantes, docentes y personal administrativo.
- **Fallas en la Cadena de Custodia Digital:** Existe el riesgo de alteración o sustitución de evidencias multimedia almacenadas dentro del expediente digital. Aunque se utilizan funciones

hash SHA-512 para garantizar integridad documental, una vulnerabilidad en almacenamiento podría comprometer la validez jurídica de los archivos.

- **Inyección sobre consultas JSONB:** El uso de búsquedas avanzadas y datos semi-estructurados mediante JSONB introduce riesgos de inyección y manipulación de consultas si no se implementan mecanismos estrictos de parametrización.
- **Pérdida de Trazabilidad Jurídica:** La ausencia de auditorías completas y registros históricos comprometería la reconstrucción del ciclo de vida de una queja y afectaría la validez procesal del expediente.
- **Exposición de Información Sensible:** Un acceso indebido a expedientes digitales podría derivar en filtración de datos personales sensibles y vulneración de privacidad institucional.

Microservicio de Inteligencia Artificial (Python)

El clasificador inteligente basado en Procesamiento de Lenguaje Natural constituye uno de los componentes críticos de apoyo a la toma de decisiones.

- **Denegación de Servicio (DoS) Semántico:** Los modelos *Sentence-Transformers* consumen recursos computacionales elevados. Narrativas excesivamente extensas o cargas concurrentes podrían saturar la memoria RAM y detener el flujo de admisión de quejas.
- **Sesgo en Clasificación Jurídica:** Errores en la determinación de competencia respecto al Artículo 4º podrían provocar el rechazo incorrecto de quejas válidas, afectando el debido proceso.
- **Deriva del Modelo (Model Drift):** Cambios progresivos en el lenguaje utilizado por la comunidad politécnica podrían degradar la precisión del modelo con el paso del tiempo.
- **Sobreajuste del Modelo:** Existe el riesgo de que el clasificador presente alto rendimiento en entrenamiento pero bajo desempeño en escenarios reales no observados previamente.
- **Falta de Explicabilidad:** Las recomendaciones automáticas generadas por el clasificador podrían dificultar la justificación jurídica de determinadas decisiones administrativas.
- **Dependencia Operativa de la IA:** Una dependencia excesiva de recomendaciones automatizadas podría reducir la supervisión humana en procesos críticos.

0.1.3 Análisis de Riesgo: Microservicio del Quejoso

El microservicio de atención al quejoso fue evaluado mediante herramientas de análisis estático de seguridad y revisión arquitectónica.

- **Indicadores de Estado:** El microservicio presenta un índice de riesgo de 0.51 y un indicador global de 90.54. No obstante, la calificación técnica de seguridad es baja, indicando la necesidad de fortalecer controles de protección.
- **Inyección Cross-site Scripting (XSS):** Se detectaron vulnerabilidades críticas asociadas a neutralización insuficiente de entradas en módulos de autenticación, perfil y gestión de trámites.
- **Debilidad Criptográfica:** Se identificó el uso de generadores pseudoaleatorios no seguros en procesos de autenticación y generación de tokens.
- **Gestión de Dependencias Obsoletas:** Se identificaron componentes con riesgo de obsolescencia tecnológica que podrían incorporar vulnerabilidades conocidas.
- **Error Humano Operativo:** Configuraciones incorrectas o manejo indebido de expedientes podrían comprometer la integridad y disponibilidad de la información.
- **Revictimización Digital:** La exposición accidental de narrativas sensibles o evidencias podría afectar psicológica y jurídicamente a las personas denunciantes.

0.1.4 Riesgos de Infraestructura y Arquitectura Distribuida

La arquitectura basada en microservicios, contenedores y orquestación introduce riesgos adicionales relacionados con disponibilidad y coordinación entre componentes.

- **Punto Único de Falla en API Gateway:** La indisponibilidad del gateway central impediría la comunicación entre microservicios y bloquearía el acceso integral a la plataforma.
- **Escalada de Privilegios en Contenedores:** Configuraciones inseguras en Docker o Kubernetes podrían permitir accesos indebidos a recursos internos del sistema.
- **Inconsistencia Transaccional:** La comunicación distribuida entre servicios podría generar estados inconsistentes entre expedientes, evidencias y notificaciones.

-
- **Fallas de Disponibilidad:** Errores en infraestructura, contenedores o balanceadores podrían afectar la continuidad operativa del sistema institucional.
 - **Dependencia de Servicios Internos:** La caída de un microservicio crítico podría impactar el funcionamiento global de la plataforma.

0.1.5 Riesgos Legales y de Cumplimiento Normativo

Debido al tratamiento de información sensible y expedientes jurídicos, la plataforma debe garantizar cumplimiento normativo y protección de derechos.

- **Incumplimiento de la LFPDPPP:** Una gestión inadecuada de datos personales podría derivar en responsabilidades administrativas y sanciones legales.
- **Violación de Confidencialidad Institucional:** La exposición de expedientes o evidencias comprometería la confianza institucional y la seguridad de las personas involucradas.
- **Incumplimiento del Debido Proceso:** Errores tecnológicos o administrativos podrían afectar la correcta atención y seguimiento de las quejas.
- **Alteración de Evidencias Digitales:** La manipulación de documentos comprometería la integridad jurídica del expediente digital.

0.1.6 Riesgos Financieros y Operativos

- **Sobrecosto Operativo por Escalamiento:** El crecimiento en procesamiento de IA y almacenamiento multimedia podría superar la capacidad presupuestal inicial.
- **Incremento en Costos de Infraestructura:** La expansión de servicios distribuidos incrementa costos de mantenimiento, monitoreo y respaldo.
- **Dependencia Tecnológica:** Actualizaciones futuras de librerías y herramientas podrían requerir inversión adicional en mantenimiento.

0.1.7 Modelo Cuantitativo de Evaluación de Riesgos

La prioridad de cada riesgo se determina mediante la siguiente relación:

$$R = P \times I$$

Donde:

- R : Nivel de riesgo
- P : Probabilidad de ocurrencia
- I : Impacto sobre el sistema

$$R = P \times I$$

La escala utilizada considera valores del 1 al 5 tanto para probabilidad como para impacto.

0.1.8 Matriz Consolidada de Riesgos

Tabla 2: Matriz Consolidada de Riesgos

ID	Riesgo	Categoría	P	I	R	Prioridad
R-01	Inyección XSS en controladores	Seguridad	5	5	25	Crítica
R-02	Clasificación jurídica incorrecta por IA	IA / Legal	4	5	20	Crítica
R-03	Exposición de datos personales	Legal	3	5	15	Alta
R-04	Saturación del motor de IA	Operacional	3	4	12	Alta
R-05	Alteración de evidencias digitales	Seguridad	3	5	15	Alta
R-06	Dependencias obsoletas	Tecnológico	3	3	9	Media
R-07	Falla del API Gateway	Infraestructura	4	4	16	Alta
R-08	Escalada de privilegios en contenedores	Infraestructura	3	5	15	Alta
R-09	Pérdida de trazabilidad jurídica	Legal	2	5	10	Media
R-10	Sobrecosto operativo	Financiero	3	3	9	Media

0.1.9 Mapa de Trazabilidad de Riesgos

Tabla 3: Trazabilidad entre Riesgos y Componentes

ID	Componente Afectado	Atributo Comprometido	Impacto Principal
R-01	Microservicio Quejoso	Seguridad	Ejecución de scripts maliciosos
R-02	Clasificador IA	Confiabilidad Jurídica	Rechazo de quejas válidas
R-03	Base de Datos PostgreSQL	Confidencialidad	Filtración de información sensible
R-04	Motor de IA	Disponibilidad	Interrupción del servicio
R-05	Repositorio de Evidencias	Integridad	Manipulación documental
R-06	Dependencias externas	Mantenibilidad	Vulnerabilidades heredadas
R-07	API Gateway	Disponibilidad	Caída general del sistema
R-08	Docker / Kubernetes	Seguridad	Acceso indebido a servicios
R-09	Sistema de auditoría	Trazabilidad	Pérdida de evidencia jurídica
R-10	Infraestructura general	Operación	Incremento presupuestal

0.1.10 Estrategias de Mitigación y Controles

Las estrategias implementadas consideran controles preventivos, detectivos y correctivos.

Tabla 4: Controles de Mitigación

Preventivos	Detectivos	Correctivos
Validación estricta de entradas	Monitoreo mediante logs y auditorías	Restauración de respaldos
Uso de TLS 1.3 y cifrado AES-256	Alertas automáticas de fallos	Actualización de dependencias
RBAC y control de acceso	Supervisión humana del clasificador	Escalamiento automático de contenedores
Uso de SecureRandom	Monitoreo de desempeño del modelo IA	Reentrenamiento periódico del modelo
Parametrización de consultas SQL	Detección de anomalías operativas	Contención de incidentes de seguridad

0.1.11 Resumen del Análisis de Riesgo

Debido a la naturaleza jurídica, institucional y tecnológica de la plataforma propuesta para la Defensoría de los Derechos Politécnicos (DDP-IPN), resulta indispensable realizar un análisis integral de riesgos que contemple amenazas técnicas, operativas, legales y organizacionales.

El sistema administra información altamente sensible relacionada con denuncias, expedientes digitales, evidencias multimedia y datos personales de la comunidad politécnica. Asimismo, integra componentes distribuidos basados en microservicios, mecanismos de inteligencia artificial y almacenamiento persistente de evidencias, incrementando la superficie de ataque y la complejidad operativa.

Con el objetivo de identificar vulnerabilidades potenciales y establecer estrategias preventivas, correctivas y detectivas, se realizó un análisis estático de seguridad (SAST), evaluación arquitectónica

y análisis de gobernanza tecnológica (GRC), considerando atributos de seguridad, disponibilidad, integridad, trazabilidad, confidencialidad y cumplimiento normativo.

0.1.12 Clasificación General de Riesgos

Los riesgos identificados se clasifican en diferentes categorías con base en el impacto que podrían generar sobre la operación de la plataforma.

Tabla 5: Clasificación General de Riesgos

Categoría	Descripción
Seguridad	Amenazas relacionadas con vulnerabilidades de software, ataques externos, robo de información y manipulación de datos.
Legal y Normativo	Riesgos asociados al incumplimiento de normativas institucionales, privacidad y protección de datos personales.
Operacional	Eventos que afectan la continuidad operativa del sistema y los procesos internos de la DDP.
Tecnológico	Problemas derivados de dependencias, infraestructura, microservicios y arquitectura distribuida.
Inteligencia Artificial	Riesgos asociados al desempeño, sesgo y comportamiento del clasificador automático.
Humano y Organizacional	Errores operativos, malas configuraciones y uso inadecuado de la plataforma por parte del personal.
Financiero	Riesgos relacionados con costos operativos, mantenimiento y escalabilidad tecnológica.

0.1.13 Análisis de Riesgo Integral del Sistema

Esta sección aborda los riesgos que afectan la cohesión de la plataforma y el flujo de trabajo institucional entre los diferentes componentes.

-
- **Fallas en la Cadena de Custodia Digital:** Riesgo de alteración o sustitución de evidencias multimedia almacenadas en el expediente. Una vulnerabilidad en el almacenamiento central podría comprometer la integridad documental y la validez jurídica de los archivos ante un proceso legal.
 - **Denegación de Servicio (DoS) Semántico en IA:** Los modelos de procesamiento de lenguaje natural (NLP) requieren recursos computacionales elevados. Cargas de trabajo concurrentes o narrativas extremadamente extensas podrían saturar la memoria RAM, deteniendo el flujo de recepción de quejas.
 - **Punto Único de Falla en API Gateway:** Al utilizar una arquitectura de microservicios, la indisponibilidad del gateway central bloquearía completamente la comunicación interna, impidiendo el acceso a cualquier funcionalidad de la plataforma institucional.
 - **Inconsistencia Transaccional Distribuida:** La comunicación entre servicios autónomos podría generar estados inconsistentes, donde un expediente sea registrado pero su procesamiento de IA o notificación falle, afectando la trazabilidad del proceso.

0.1.14 Análisis de Riesgo Específico: Microservicio del Quejoso

Basado en los reportes de análisis estático (SAST) realizados al código fuente del módulo, se identificaron los siguientes riesgos técnicos específicos:

- **Inyección Cross-site Scripting (XSS):** Se detectaron vulnerabilidades críticas en controladores como *AuthController* y *QuejaController* debido a una neutralización insuficiente de entradas. Esto permitiría la ejecución de scripts maliciosos en el navegador de los administradores.
- **Debilidad Criptográfica (PRNG no seguro):** El uso de generadores pseudoaleatorios estándar en el servicio de usuarios compromete la seguridad de tokens y contraseñas temporales, haciéndolos predecibles para un atacante con conocimientos técnicos.
- **Obsolescencia de Dependencias:** El sistema cuenta con componentes de terceros (Jakarta, Hibernate) con riesgos de mantenimiento. La falta de actualizaciones podría exponer al microservicio a vulnerabilidades conocidas públicamente (CVEs).
- **Indicadores de Seguridad:** Aunque el índice de riesgo global es aceptable (0.51), el indicador técnico de seguridad es bajo, requiriendo un esfuerzo de remediación estimado de 2.5 horas para corregir defectos de alta prioridad.

0.1.15 Estrategias de Mitigación y Controles

A continuación, se describen brevemente las acciones preventivas y correctivas diseñadas para reducir el impacto de los riesgos detectados.

- **Saneamiento y Validación de Entradas:** Implementar filtros de limpieza en el servidor para eliminar cualquier rastro de código HTML o scripts en los formularios de queja y perfil de usuario, mitigando ataques de inyección.
- **Fortalecimiento de Criptografía:** Reemplazar el uso de clases aleatorias estándar por *SecureRandom* con semillas de alta entropía para garantizar que la generación de identificadores y tokens sea matemáticamente impredecible.
- **Gestión de Actualizaciones (Patch Management):** Establecer un cronograma de revisión de dependencias para actualizar librerías obsoletas, priorizando aquellas que presenten riesgos de seguridad medios o altos.
- **Supervisión Humana en Procesos de IA:** Implementar un protocolo donde toda decisión sugerida por el clasificador de IA deba ser ratificada por un operario jurídico, evitando errores por sesgo o derivación del modelo.
- **Implementación de Hash de Integridad:** Generar y almacenar una firma digital (SHA-512) por cada evidencia cargada, permitiendo verificar en cualquier momento que el archivo no ha sido manipulado desde su origen.

0.1.16 Resumen del Análisis de Riesgo

El análisis de riesgo presentado integra una evaluación integral de la plataforma institucional, combinando hallazgos técnicos específicos del microservicio del quejoso con los riesgos operativos y legales del sistema completo.

Se destaca que, si bien la arquitectura basada en microservicios e Inteligencia Artificial aporta escalabilidad y eficiencia, también introduce puntos críticos como la dependencia del API Gateway y el consumo elevado de recursos. Los hallazgos del análisis SAST revelaron vulnerabilidades de inyección y debilidad criptográfica que deben ser atendidas con prioridad máxima. No obstante, mediante la aplicación de las estrategias de mitigación propuestas —que incluyen saneamiento de datos, supervisión humana y gobernanza tecnológica— se concluye que el sistema posee la viabilidad

técnica y normativa necesaria para operar de manera segura y resiliente dentro de la Defensoría de los Derechos Politécnicos.